Hybrid Post-Quantum Key Exchange for WireGuard

Integrating ML-KEM into a Production Rust Userspace Implementation

Mihai-Cristian Farcaș

Babeș–Bolyai University
Faculty of Mathematics and Computer Science

Bachelor's Thesis Defense | June 2026

Supervisor: Prof. Dr. Darabant Sergiu Adrian

Roadmap

1. The problem – why WireGuard needs post-quantum key exchange
2. Two approaches – PSK-slot baseline & full hybrid
3. The hybrid handshake (design)
4. Implementation – BoringTun and the `pq` feature
5. Security analysis & evaluation
6. Conclusions

Motivation: the quantum clock is already running

- WireGuard's key exchange rests entirely on X25519.
- Shor's algorithm breaks X25519 once a large quantum computer exists.
- **Harvest-now, decrypt-later:** adversaries can record encrypted traffic *today* and decrypt it *later*.

$\Rightarrow$ For long-lived secrets, migration is urgent *now*.

The standards landscape

NIST finalised **FIPS 203 (ML-KEM)** in Aug 2024 – the standard for key exchange.
Classical key exchange to be **deprecated by 2030**, disallowed by 2035.

WireGuard: important, but hard to migrate

- Fixed cipher suite, **no negotiation** – a security feature (kills downgrade attacks)...
- ...but no built-in way to swap the key-exchange algorithm.

Two natural handles for post-quantum augmentation

1. The **PSK slot** – a 256-bit symmetric key mixed into the handshake's key derivation.
2. The **Noise IK handshake** itself – embed a KEM alongside X25519 in every handshake.

This thesis builds on **both**.

Research question and two approaches

Research question

Can WireGuard's handshake be extended with **hybrid post-quantum key exchange (X25519 + ML-KEM-768)** while preserving its security properties and staying viable on **resource-constrained hardware**?

A. PSK-slot baseline

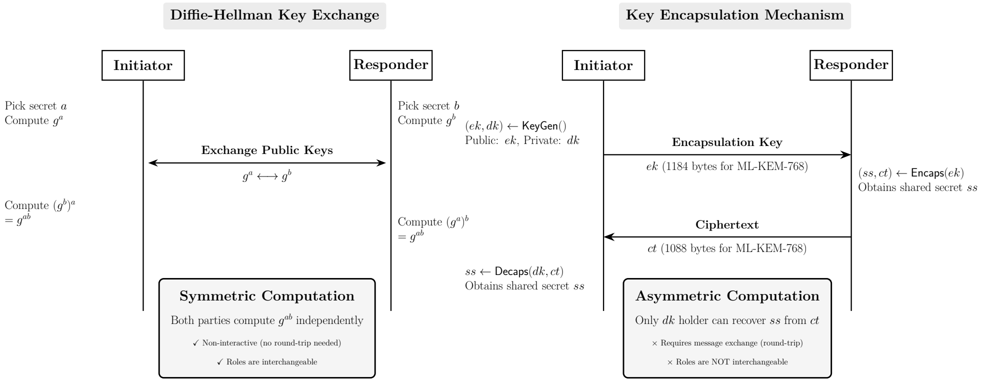
- One-time ML-KEM exchange out-of-band → fill the PSK slot.
- **Zero** WireGuard changes; works with any client.
- The *lower bound* on engineering effort – a controlled comparison point.

B. Full hybrid (the contribution)

- ML-KEM-768 *inside* the Noise IK handshake, every session.
- Fresh KEM keypair per handshake.
- Target: **BoringTun** (Cloudflare's production Rust userspace WireGuard).

To our knowledge, the first FIPS 203-compliant *hybrid* WireGuard on a production codebase.

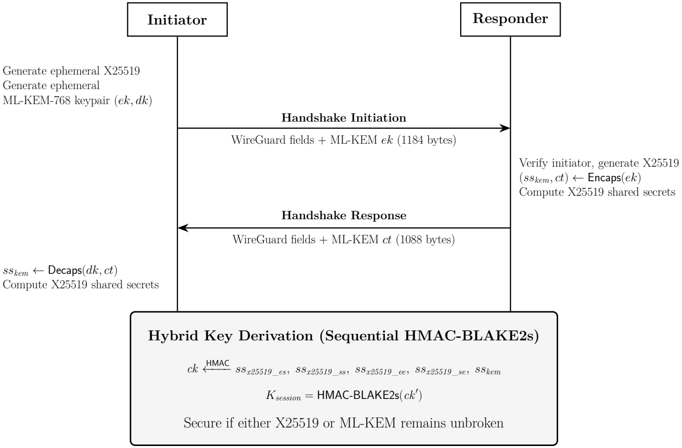
Just enough background: a KEM is not a Diffie–Hellman



Hybrid

X25519 is a symmetric DH; ML-KEM *encapsulates* / *decapsulates* (asymmetric – this shapes the handshake). The hybrid folds *both* secrets together via concatenate-then-KDF (NIST SP 800-56C; the TLS 1.3 pattern). **Secure if *either* X25519 *or* ML-KEM survives.**

The hybrid handshake: ML-KEM rides the existing two messages



- **Msg 1:** WG fields + ML-KEM *ek* (1,184 B)
- **Msg 2:** responder runs Encaps + *ct* (1,088 B)
- Initiator Decaps → both share ss_{kem}

No extra round trips. *ek*/*ct* sit *before* the MACs, so the anti-DoS cookie still covers the PQ payload.

Combining the secrets – and what stays untouched

One extra mixing step, using WireGuard's own KDF

After the four X25519 secrets are mixed in as usual, fold in ss_{kem}:

$$temp = \text{HMAC-BLAKE2s}(ck,\ ss_{kem}), \qquad ck' = \text{HMAC-BLAKE2s}(temp,\ \texttt{0x01})$$

ek and ct are also bound into the transcript hash h.

- **Reuses WireGuard's HMAC-BLAKE2s** – no new HKDF/SHA-256 introduced; keeps the security argument clean.
- Transport phase is byte-for-byte unchanged – ChaCha20-Poly1305 untouched. *This is why throughput is identical.*

Implementation

- All PQ code behind a Cargo `pq` feature flag ⇒ **a vanilla build is byte-for-byte identical to upstream**.
- `ml-kem` crate (RustCrypto): pure-Rust, `no_std`, NIST KAT-tested ⇒ runs on the Pi, **no C FFI**.
- New message types **5** (PQ init) and **6** (PQ response); parser dispatches on type+size; a vanilla build cleanly rejects them (`InvalidPacket`).
- Memory-safe Rust; minimal carried state (initiator keeps only dk, responder only ek).

Testing

Extended BoringTun's own Criterion benchmarks and `noise::tests`: full PQ handshake, end-to-end transport, ML-KEM/PSK orthogonality, and vanilla-rejects-PQ.

Security analysis

Hybrid-secure

The session key is indistinguishable from random if **X25519 *or* ML-KEM** is secure (concatenate-then-KDF; HMAC-BLAKE2s as a PRF).

- **Post-quantum forward secrecy:** fresh ML-KEM keypair *per handshake* ⇒ past sessions stay safe even if X25519 later falls.
  The PSK-slot baseline **cannot** match this: a static PSK, one compromise exposes many sessions.
- **Authentication stays classical** (X25519 static keys) – *deliberate*: it cannot be broken *retroactively*, and NIST prioritises key-exchange migration over signatures. ML-DSA is future work.

Evaluation – handshake latency (Criterion, 95% CI)

Configuration	Apple M4	Raspberry Pi 5
Vanilla	150.8 μs	1312 μs
PSK-slot	151.0 μs	1312 μs
Hybrid	**247.3 μs (+64%)**	**1643 μs (+25%)**

- Overhead $\approx$ the three ML-KEM ops ($\approx$73 μs M4 / $\approx$280 μs Pi); the rest is bigger buffers + an extra hash pass.
- It is 64% of a *sub-millisecond, crypto-only* cost – over a real link, RTT dominates and the data plane is untouched.
- **Surprise:** on the Pi, one X25519 DH (193 μs) is *slower* than any ML-KEM op – `x25519-dalek` lacks NEON; ML-KEM's NTT maps well to the integer pipeline.

Evaluation – size, throughput, footprint

- **Packet size is the real cost:** handshake grows **240 B → 2,512 B** (+2,272 B). Both messages still fit a 1,500 B Ethernet MTU in a single datagram – confirmed over real Wi-Fi, no fragmentation.
- **Throughput unchanged:** ∼470 Mbps loopback, ∼80–85 Mbps cross-device; vanilla vs hybrid CIs overlap (same ChaCha20-Poly1305 data plane).
- **Footprint negligible:** binary **+65 KiB** (+5.7%), peak RSS **+0.16 MiB** – a non-issue even on the Pi.

The cost of the hybrid is *size*, not time – and the size still fits.

Conclusions

Contributions

1. First FIPS 203-compliant *hybrid* WireGuard on a production Rust codebase.
2. A PSK-slot baseline as a controlled comparison point.
3. A hybrid Noise IK handshake with *post-quantum forward secrecy*.
4. Evaluation across two ARM tiers (Apple M4, Raspberry Pi 5).

Bottom line: hybrid PQ WireGuard is **practical today** – NIST-aligned, userspace-deployable, sub-millisecond overhead, data plane untouched.

Future work: MTU strategies (segmentation / PMTUD); ML-DSA authentication; a formal proof; ML-KEM parameter agility.

Thank you.

Questions?

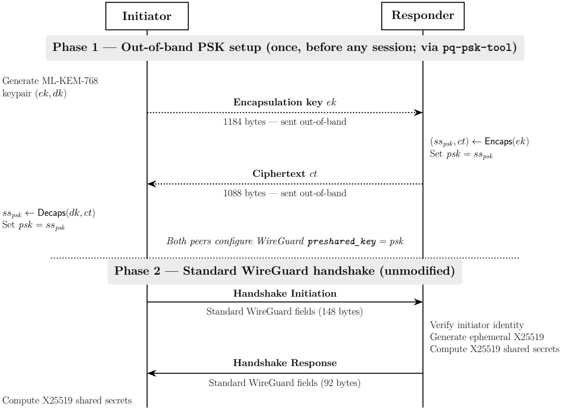
Mihai-Cristian Farcaș | Supervisor: Prof. Dr. Darabant Sergiu Adrian

Backup – per-primitive microbenchmarks (Criterion)

Operation	Apple M4	Raspberry Pi 5
ML-KEM-768 KeyGen	24.13 μs	81.66 μs
ML-KEM-768 Encaps	20.82 μs	82.77 μs
ML-KEM-768 Decaps	28.03 μs	115.15 μs
X25519 KeyGen	8.77 μs	58.00 μs
X25519 DH	20.39 μs	192.81 μs

On the Pi, a single X25519 DH costs more than any ML-KEM operation.

Backup – the PSK-slot baseline



PSK Key Derivation

$$ck \xleftarrow{\mathsf{HMAC}} ss_{x25519\_es},\ ss_{x25519\_ss},\ ss_{x25519\_ee},\ ss_{x25519\_se} \text{ then } \xleftarrow{\mathsf{HMAC}} psk$$

$$K_{session} = \mathsf{HMAC\text{-}BLAKE2s}(ck')$$

The out-of-band psk is the only post-quantum input; the handshake messages are unchanged

Backup – MTU & interoperability

- Hybrid initiation 1,332 B; fragmentation only on paths below ~1,360 B (e.g. IPv6's 1,280 B minimum).
- **Lowering the WireGuard MTU does *not* help** – that shrinks data packets, not the fixed-size handshake. The fix must live in the handshake (app-level segmentation / PMTUD – future work).
- Interop: a vanilla peer drops PQ types 5/6 at dispatch (`InvalidPacket`); no crash, but no auto-fallback – both peers must be hybrid-capable. Capability negotiation is engineering, not fundamental.

Backup – why ML-KEM-768, why hybrid

- **ML-KEM-768:** NIST Level 3 ($\sim$AES-192); the general-purpose default recommended by NIST/IETF; balances size vs security.
- **Hybrid, not pure-PQ:** the MLWE assumption is young; pairing with X25519 means a future lattice break still leaves sessions protected. NIST and IETF recommend hybrid for the transition.
- **vs related work:** PQ-WireGuard is pure-PQ on prototypes with non-standard KEMs; Rosenpass/ExpressVPN carry PQ secrets through the PSK slot. This work modifies the Noise handshake directly, on production code, with standardised ML-KEM – complementary to the formal Hybrid-WireGuard proof (Lafourcade et al.).